

ГЛАВНОЕ: что требуется, что сделано, что делать

ГЛАВНОЕ_Что_делать_и_что_проверить.md

Редакция 2 от 16.08.2026 — сверена по полным текстам первоисточников: Федеральный закон от 27.07.2006 № 152-ФЗ (действующая редакция) и приказ Роскомнадзора от 19.06.2025 № 140 (зарег. Минюстом 31.07.2025 № 83110).

Заменяет редакцию 1. Точка входа во весь комплект.

0. Что изменилось после сверки с первоисточниками

Редакция 1 строилась на правовых агрегаторах. Полные тексты дали три исправления, все в пользу самозанятого, и два ужесточения, которых я раньше не называл.

Исправления (ранее было сказано строже, чем требует закон)

Что говорилось в редакции 1	Что в законе на самом деле
«Приказ о назначении ответственного за организацию обработки — РО, обязателен»	П. 1 ч. 1 ст. 18.1: «назначение оператором, являющимся юридическим лицом, ответственного...». Ст. 22.1 ч. 1: «Оператор, являющийся юридическим лицом, назначает лицо, ответственное...». Для физического лица обязанность не установлена
«Издать политику и локальные акты — обязанность»	П. 2 ч. 1 ст. 18.1: «издание оператором, являющимся юридическим лицом, документов, определяющих политику...». Обязанность издавать локальные акты — только для юрлиц
«Оценка эффективности мер — не реже раза в 3 года»	П. 4 ч. 2 ст. 19: оценка эффективности проводится «до ввода в эксплуатацию информационной системы персональных данных». Периодичность раз в 3 года — из приказа ФСТЭК № 21, а не из закона

Ужесточения (ранее не называлось)

Норма	Что требует
Ч. 5 ст. 18 в ред. ФЗ от 28.02.2025 № 23-ФЗ	Формулировка изменена с «оператор обязан обеспечить» на прямой запрет : «...запись, систематизация, накопление, хранение, уточнение, извлечение персональных данных граждан Российской Федерации с использованием баз данных, находящихся за пределами территории Российской Федерации, не допускаются», кроме случаев по пп. 2, 3, 4, 8 ч. 1 ст. 6 (к вам не относятся)
П. 3.1 ч. 2 ст. 19 (введён ФЗ от 08.08.2024 № 233-ФЗ)	Для уничтожения персональных данных должны применяться прошедшие оценку соответствия средства защиты информации, в составе которых реализована функция уничтожения информации . Это прямо про ваш случай: удаление задания из памяти — операция уничтожения
Ч. 6 ст. 6	Если обработка поручена иностранному лицу, ответственность перед субъектом несут и оператор, и обработчик . Актуально, если шлюз окажется иностранным (вопрос 3.1)

1. ЧТО КОНКРЕТНО ТРЕБУЕТСЯ ОТ ВАС

1.1. Обязанности, действующие ВСЕГДА (независимо от формы и модели)

Норма	Требование	Ваш статус
Ч. 1 ст. 18.1	Принимать меры, необходимые и достаточные для выполнения обязанностей. Состав мер оператор определяет самостоятельно	Частично
П. 3 ч. 1 ст. 18.1 + ст. 19	Правовые, организационные и технические меры безопасности	Частично
Ч. 2 ст. 18.1	Опубликовать документ, определяющий политику в отношении обработки ПДн. Оговорки «являющийся юридическим лицом» здесь нет — при сборе ПДн через интернет обязанность распространяется и на физлицо	✗ Не сделано
П. 4 ч. 1 ст. 18.1	Внутренний контроль соответствия	✗
П. 5 ч. 1 ст. 18.1	Оценка вреда субъектам	✗
Ст. 22	Уведомление Роскомнадзора до начала обработки . Исключения ч. 2 — только ГИС безопасности государства, обработка исключительно без средств автоматизации , транспортная безопасность. Для физлиц исключений нет	✗
Ч. 7 ст. 22	При изменении сведений — уведомить не позднее 15-го числа месяца, следующего за месяцем изменения. При прекращении обработки — в течение 10 рабочих дней	—
Ч. 5 ст. 18	Запрет использования баз данных за пределами РФ	☒ Устранено
Ч. 3.1 ст. 21	Уведомление РКН об инциденте: 24 часа — о факте, причинах, предполагаемом вреде, принятых мерах и уполномоченном лице; 72 часа — о результатах внутреннего расследования и лицах, чьи действия стали причиной	✗ Регламента нет
Ч. 2 ст. 19	Определение угроз; меры под установленный ПП РФ уровень защищённости; применение прошедших оценку соответствия СЗИ; СЗИ с функцией уничтожения — для уничтожения ПДн; оценка эффективности до ввода в эксплуатацию; учёт машинных носителей; обнаружение НСД; правила доступа и регистрация всех действий с ПДн в ИСПДн	✗
Ст. 7	Конфиденциальность: не раскрывать и не распространять без согласия субъекта	☒

1.2. Обязанности ТОЛЬКО для юридических лиц — на вас сейчас НЕ распространяются

Норма	Требование
П. 1 ч. 1 ст. 18.1, ч. 1 ст. 22.1	Назначение ответственного за организацию обработки ПДн
П. 2 ч. 1 ст. 18.1	Издание документов, определяющих политику, и локальных актов
П. 6 ч. 1 ст. 18.1	Ознакомление работников — у самозанятого работников нет по ч. 7 ст. 2 ФЗ-422

Практическая оговорка. Ч. 2 ст. 18.1 всё равно обязывает **опубликовать** документ о политике. То есть политику написать придётся — но как публикуемый документ по ч. 2, а не как локальный акт по п. 2 ч. 1. Разница в том, что обязательных требований к её внутреннему содержанию для физлица закон не предъявляет, а форма и объём остаются на ваше усмотрение.

И главное: заказчик уровня ИНК потребует весь комплект независимо от закона. Отсутствие приказа о назначении ответственного — блокирующий пункт вендорского опросника, даже если по закону вы его издавать не обязаны.

1.3. Требования приказа РКН № 140 — применяются НЕ ВСЕГДА

Приказ адресован оператору и только при обезличивании (п. 9 ст. 3). Отсюда:

Ваша конфигурация	Применяется ли приказ № 140
Маскирование, термин «обезличивание» не используется	Нет. Предмет приказа — обезличивание
Вы оператор, режим обезличивания	Да, напрямую
Вы обработчик по поручению, оператор — заказчик	Адресат — заказчик. К вам требования придут договором

Полные требования (приложение № 1, п. 1): методы из приложения № 2 · определение состава ПДн и субъектов **до начала** · оценка достаточности метода · невозможность идентификации без дополнительной информации · ИС, обеспечивающая безопасность и конфиденциальность · **исключение совместного хранения исходного массива и результата** · учёт действий в определённой оператором форме.

Приложение № 2, п. 2 и 3 — ваш метод: **введение идентификаторов**; ключ **создаётся**, хранится оператором **отдельно** и **не передаётся** третьим лицам.

2. ЧТО УЖЕ СДЕЛАНО 16.08.2026

Область	Сделано	Закрывает
Локализация	web/vercel.json (регион fra1) удалён, кодовая база вычищена, составлен акт 01	Ч. 5 ст. 18

Область	Сделано	Закрывает
Терминология	«Обезличивание» → «маскирование/псевдонимизация» во всех внешних текстах; правовые оговорки; глоссарий 05	Ст. 431.2 ГК — риск недостоверных заверений
Секреты	Захардкоженный JupyterHub-токен и URL вынесены в окружение; запись об инциденте 08	Ст. 19 ч. 1
CORS	Access-Control-Allow-Origin: * убран; заголовок не отдаётся вне явного белого списка	Ст. 19 ч. 2 п. 8
Ключ деанонимизации	spans[].text (второй, более полный ключ) не возвращается; режим irreversible — ключ не формируется	П. 1.4, 1.6 приказа № 140
Хранение	Детерминированный TTL, одноразовая выдача (опция), запрет core dump	П. 1.6 приказа № 140; ст. 19
Учёт	depersonalization_log.py — форма учёта без содержимого ПДн, права 0600	П. 1.7 приказа № 140; ст. 19 ч. 2 п. 8

Регрессия: тесты **265 passed / 29 failed** — идентично состоянию до правок.

3. МОЖНО ЛИ ВСЁ СДЕЛАТЬ КАК САМОЗАНЯТЫЙ

Ответ: да, весь обязательный минимум — можно. Причём требований к вам меньше, чем к юрлицу.

Действие	Может ли самозанятый	Основание
Быть оператором ПДн	☒ Да	П. 2 ст. 3: «юридическое или физическое лицо »
Быть лицом, осуществляющим обработку по поручению	☒ Да	Ч. 3 ст. 6 — требований к форме нет
Заклучить договор поручения обработки	☒ Да	Ч. 3 ст. 6
Подать уведомление в РКН	☒ Да, и обязан	Ст. 22; п. 1 ч. 3: «наименование (фамилия, имя, отчество), адрес оператора»
Опубликовать политику	☒ Да, и обязан при сборе через интернет	Ч. 2 ст. 18.1

Действие	Может ли самозанятый	Основание
Назначить ответственного	— Не обязан	П. 1 ч. 1 ст. 18.1, ч. 1 ст. 22.1 — только юрлица
Издавать локальные акты	— Не обязан	П. 2 ч. 1 ст. 18.1 — только юрлица
Принимать меры по ст. 19	☑ Да, и обязан	Ч. 1 ст. 18.1, ст. 19 — оговорки о юрлице нет
Быть правообладателем в реестре российского ПО	☑ Да	ПП РФ № 1236 — гражданин РФ без двойного гражданства
Получить лицензию ФСТЭК	✗ Нет	Только юрлица и ИП. По анализу вам не требуется

Где самозанятость всё же упирается

Ограничение	Норма	Последствие
Лимит дохода 2 400 000 Р в год	П. 8 ч. 2 ст. 4 ФЗ-422	При превышении статус прекращается в тот же день ; чек сформировать нельзя → оплату по контракту принять невозможно
Запрет найма работников	Ч. 7 ст. 2 ФЗ-422	Команду не собрать
Неограниченная личная имущественная ответственность	Ст. 24 ГК	При регрессе взыскание на личное имущество
Корпоративная закупка	Практика	ИНК поставщика-физлицо, как правило, не проводит

Вывод. Для выполнения требований 152-ФЗ самозанятости достаточно, и обязанностей у вас меньше. Для сделки с ИНК и для публичного стартапа — нет, нужно ООО. Регистрировать параллельно, не откладывая подписание договора поручения с Интерфониной.

4. ВАРИАНТ «СТАРТАП ДЛЯ ВСЕХ ЖЕЛАЮЩИХ»: ОФЕРТА ИЛИ ОТДЕЛЬНЫЙ ДОГОВОР

4.1. Развилка ролей

Модель	Кто оператор	Кто вы	Правовое основание обработки
Отдельный договор с каждым клиентом (B2B)	Клиент	Обработчик по поручению	Основание клиента; ваше согласие не требуется — ч. 4 ст. 6
Публичная оферта, подключение по ссылке	Спорно: формально клиент, фактически претензии придут к вам	Оператор либо обработчик — зависит от конструкции оферты	Собственного основания нет

4.2. Почему оферта юридически работает — и где её слабое место

Работает. Ч. 3 ст. 6 требует, чтобы поручение оформлялось «на основании заключаемого с этим лицом договора». Договор присоединения (ст. 428 ГК) — договор. Норма не требует ни бумажной формы, ни подписания каждым клиентом отдельно. Ч. 4 ст. 6 прямо освобождает обработчика от получения согласия субъектов.

Слабое место — не форма договора, а достоверность заверений. Пользователь заверяет, что он оператор и вправе передавать данные. Проверить вы это не можете. Если заверение ложно, то поручения фактически нет, а обработка идёт без основания — и отвечать перед Роскомнадзором будете вы.

4.3. Что обязательно должно быть в оферте — прямо по ч. 3 ст. 6

Норма перечисляет обязательные условия поручения. **Отсутствие любого — поручение считается неоформленным:**

№	Условие	Формулировка закона
1	Перечень персональных данных	«должны быть определены перечень персональных данных»
2	Перечень действий (операций)	«перечень действий (операций) с персональными данными»
3	Цели обработки	«цели их обработки»
4	Обязанность соблюдать конфиденциальность	«должна быть установлена обязанность такого лица соблюдать конфиденциальность»
5	Требования ч. 5 ст. 18 (локализация) и ст. 18.1	«требования, предусмотренные частью 5 статьи 18 и статьей 18.1»
6	Обязанность по запросу оператора предоставлять документы, подтверждающие	«обязанность по запросу оператора... в том числе до обработки персональных данных, предоставлять

№	Условие	Формулировка закона
	принятие мер — в том числе до начала обработки	документы и иную информацию, подтверждающие принятие мер»
7	Обязанность обеспечивать безопасность	«обязанность обеспечивать безопасность персональных данных при их обработке»
8	Требования к защите по ст. 19	«должны быть указаны требования к защите обрабатываемых персональных данных в соответствии со статьёй 19»
9	Уведомление оператора о случаях по ч. 3.1 ст. 21	«требование об уведомлении оператора о случаях, предусмотренных частью 3.1 статьи 21»

Плюс, специфично для оферты: заверения пользователя (ст. 431.2 ГК) о наличии у него основания и об исполнении обязанности информирования субъектов; согласие на привлечение субобработчиков по перечню; запрет загрузки специальных категорий (ст. 10), биометрии (ст. 11) и сведений, составляющих государственную тайну.

4.4. Что меняется в требованиях при переходе к публичной модели

Параметр	Отдельный договор	Публичная оферта
Число субъектов	Контролируемо	Быстро превысит 100 000 → штраф за утечку 10–15 млн Р , повтор — оборотный от 20 млн
Специальные категории	Запрещаются договором и проверяются	Попадут неизбежно → уровень защищённости УЗ-2 → обязательны сертифицированные СЗИ (п. 3 ч. 2 ст. 19)
Ограничение ответственности	Договором	С потребителями ничтожно (ст. 16 ЗоЗПП)
Уведомление в РКН	Обязательно	Обязательно, с широким перечнем категорий субъектов
Форма	Самозанятый допустим	Только ООО

4.5. Условия, без которых публичный запуск делать нельзя

Архитектурные — до запуска:

1. **Полностью stateless**: ни документ, ни ключ не сохраняются. *Утечь может только то, что хранится.* Это снимает основную часть рисков разом.
2. Режим irreversible по умолчанию — ☒ **реализовано.**
3. spans[].text выключен — ☒ **реализовано.**
4. Журнал операций без содержимого — ☒ **реализовано.**
5. Аутентификация, ограничение частоты запросов, лимит объёма — ☒ **✗.**
6. Технический отказ при признаках специальных категорий — ☒ **✗** (удерживает УЗ-3 вместо УЗ-2).

7. **СЗИ с функцией уничтожения, прошедшее оценку соответствия** — п. 3.1 ч. 2 ст. 19.

✗ Требуется отдельной проработки: норма новая, практика не сложилась.

Юридические: ООО · оферта по п. 4.3 · уведомление в РКН до запуска · опубликованная политика (ч. 2 ст. 18.1) · порядок реагирования на обращения субъектов · оценка вреда (п. 5 ч. 1 ст. 18.1).

[РЕКОМЕНДАЦИЯ] Порядок: сначала B2B с ИНК (роль обработчика, ответственность ограничена договором, объём контролируем) → на выручке довести до stateless → затем публичный запуск от ООО.

5. СЕРВЕР С ЛИЦЕНЗИЕЙ: САЙТ И БЭКЕНД (LLM + GLiNER) У ПРОВАЙДЕРА

Если и фронтенд, и Python-бэкенд, и инференс (LLM + GLiNER) размещены на аттестованной площадке провайдера в РФ, картина упрощается **существенно**:

Что закрывается	Чем
Ч. 5 ст. 18 (локализация)	Базы данных на территории РФ. Запрет не нарушается
Ст. 12 (трансграничная передача)	Передачи за пределы РФ нет → уведомление по ч. 3 ст. 12 не требуется
Ч. 6 ст. 6 (солидарная ответственность при иностранном обработчике)	Не применяется
Часть мер ст. 19 на уровне инфраструктуры	Аттестат провайдера

Но это НЕ закрывает и требует подтверждения:

- Передача на шлюз остаётся передачей другому лицу.** Даже внутри одного ЦОДа `oui.interfonica.cloud` — это ресурс провайдера, а не ваш. Нужен **договор поручения** по ч. 3 ст. 6 со всеми девятью условиями из п. 4.3. Размещение в одном ЦОДе этого не заменяет.
- Область действия аттестата.** Аттестат № 1068.00022.2024 выдан на АИС «Инфраструктура» ООО «Интерфоника». Нужно письменное подтверждение, что **ваш контур и мощности шлюза входят в область его действия** (02, Блок 5). Иначе заявлять «размещено в аттестованном сегменте» нельзя.
- Ваша ИСПДн — отдельный объект защиты.** Ч. 1 и 2 ст. 19 обязывают оператора определять угрозы и принимать меры применительно к **своей** системе. Аттестат провайдера этого не исполняет.
- Матрица разграничения ответственности** по мерам приказа ФСТЭК № 21 — какие закрывает провайдер, какие вы. Без неё на аудите обе стороны считают, что меру закрывает другая.
- Уходит ли запрос дальше** за пределы контура провайдера (02, Блок 1, вопрос 1.3). Если есть апстрим — всё сказанное выше может не действовать.

6. ЧТО ДЕЛАТЬ — ИТОГОВЫЙ ЧЕКЛИСТ

Немедленно (дни 1–3)

Действие	Основание
Отозвать JupyterHub-токен, затем ротировать ключ шлюза	08
Направить запрос в ООО «ИНТЕРФОНИКА» — 12 блоков + матрица ФСТЭК № 21	02
Подтвердить документально: область аттестата покрывает ваш контур и шлюз	Ст. 19
Установить, обрабатывались ли ПДн реальных субъектов	Определяет срок по ст. 22 и ст. 21
Проверить территорию размещения anon.spcore.ru	Ч. 5 ст. 18

Дни 3–14

Действие	Основание
Подписать договор поручения с Интерфоникой — как самозанятый, все 9 условий ч. 3 ст. 6	Ч. 3 ст. 6
Написать и опубликовать политику обработки ПДн	Ч. 2 ст. 18.1
Подать уведомление в РКН	Ст. 22
Регламент реагирования на инциденты: 24 ч / 72 ч, формы уведомлений	Ч. 3.1 ст. 21
Аутентификация входящих запросов; привязка job_id к субъекту	Ст. 19 ч. 2 п. 8
Убрать имя файла из usage.json1	Ст. 19
Подать документы на регистрацию ООО	06

Дни 14–30

Действие	Основание
Определение угроз безопасности (модель угроз)	П. 1 ч. 2 ст. 19

Действие	Основание
Акт определения уровня защищённости	П. 1 ч. 3 ст. 19; ПП РФ № 1119
Оценка эффективности мер — до ввода в эксплуатацию	П. 4 ч. 2 ст. 19
Оценка вреда субъектам	П. 5 ч. 1 ст. 18.1
Раздельная выдача документа и ключа	П. 1.6 приказа № 140
Проработать применение СЗИ с функцией уничтожения	П. 3.1 ч. 2 ст. 19
Режим коммерческой тайны; NDA; шаблон договора с заказчиком	98-ФЗ
LICENSE, NOTICE, THIRD_PARTY_LICENSES.md	Apache-2.0 §4; CC BY-SA
Отчуждение исключительного права в пользу ООО; замена стороны в договоре	ГК

Только при выборе режима обезличивания

Локальный акт «Порядок обезличивания» (п. 2.1 приказа № 140) · Протокол оценки достаточности метода (п. 1.3) · Заккрытие публичного описания алгоритма (п. 2.2) · Форма учёта утверждается актом (п. 1.7).

7. Открытые вопросы, от которых зависят выводы

№	Вопрос	Что изменится
1	Физическое размещение мощностей шлюза; наличие апстрима	Вне РФ → запрет по ч. 5 ст. 18 и обязанность по ст. 12; ч. 6 ст. 6 — солидарная ответственность
2	Область действия аттестата покрывает ваш контур?	Нет → заявлять об аттестации нельзя
3	Логируются ли промпты у провайдера	Логируются → ваши документы хранятся у третьего лица
4	Обрабатывались ли ПДн реальных субъектов	Да → обязанности по ст. 22 и, возможно, ст. 21 уже возникли
5	Был ли скомпрометирован токен	Есть чужие обращения → уведомление РКН за 24 часа

№	Вопрос	Что изменится
6	Планируются ли специальные категории ПДн	Да → УЗ-2 → сертифицированные СЗИ

8. Дисклеймер

Анализ основан на полных текстах 152-ФЗ и приказа Роскомнадзора № 140 по состоянию на 16.08.2026 и **не заменяет** заключение практикующего юриста по персональным данным и аудит информационной безопасности. Суммы административных штрафов приведены по вторичным источникам и подлежат сверке с текстом КоАП РФ. Правоприменительная практика по приказу № 140, по п. 3.1 ч. 2 ст. 19 и по редакции ст. 13.11 КоАП, действующей с 30.05.2025, не сформирована. Перед подписанием договора с корпоративным заказчиком обязательны правовая экспертиза договора и независимый аудит ИБ.